Scenario:

A hospital uses an online system to store **patient medical records**. An attacker discovers that the hospital's web application has a **weak login mechanism** that has not been properly secured. The attacker obtains a user's login credentials through a **phishing email** and uses them to log into the system. After gaining access, the attacker downloads confidential patient records and deletes some important appointment information.

Questions

Identify the following from the scenario:

1. **Asset:** What is being protected?
2. **Threat:** What is the danger?
3. **Vulnerability:** What is the weakness?
4. **Exploit:** What technique/action is used to take advantage of the weakness?
5. **Attack:** What has the attacker actually done?
6. **Attack Vector:** Through which route did the attacker gain access?
7. **Payload:** What harmful action/data did the attack deliver?
8. **Risk:** What could happen to the hospital and patients?
9. **CIA Triad:** Which of **Confidentiality, Integrity, Availability** are affected?

Question

If the hospital had enabled MFA, how could it have reduced the risk in this scenario?

Term	Answer
1. Asset	**Patient medical records, appointment information, and the hospital's online system.**
2. Threat	**The attacker/hacker** who attempts to gain unauthorized access and steal or delete information.
3. Vulnerability	**Weak/poorly secured login mechanism** in the hospital's web application.
4. Exploit	**Using stolen login credentials** to take advantage of the weak authentication/security.
5. Attack	**The attacker logs into the system without authorization, downloads patient records, and deletes appointment information.**
6. Attack Vector	**Phishing email** used to obtain the user's login credentials.
7. Payload	**The stolen patient records and deletion of appointment information** are the harmful outcomes delivered by the attack.
8. Risk	**Loss of patient privacy, data theft, disruption of hospital services, and loss/corruption of appointment information.**
9. CIA Triad	**Confidentiality:** patient records were stolen. **Integrity:** appointment information was deleted. **Availability:** potentially affected if deletion prevents users from accessing required information.

Answer

If MFA had been enabled**,** the stolen username and password alone would generally not have been sufficient to log in. The attacker would also need the additional authentication factor, such as an OTP, authenticator-app approval, or biometric verification**.**